

WEEK 3 DOCUMENTATION FINDINGS

Intern: Muhammad Saim Ali Khan

ID: DHC-4044

Role: Cyber Security Analyst Intern

1. BASIC PENETRATION TESTING

To verify the effectiveness of the security measures implemented in Week 2, I conducted a final round of penetration testing.

- **SQL Injection Test:** Attempted ' OR 1=1 -- on the login and search modules. The application successfully rejected these attempts due to parameterized queries.
- **JWT Bypass Test:** Attempted to access /list and /delete without a token. The system returned 401 Unauthorized, confirming the middleware is active.
- **XSS Execution Test:** Attempted script injection in user input fields. Inputs were either sanitized or blocked by the Content Security Policy (CSP).

2. SET UP BASIC LOGGING

I implemented a logging system using the `winston` library to track security-related events and maintain an audit trail for future investigations.

Implementation (security-logger.js):

```
const winston = require('winston');
```

```
const logger = winston.createLogger({  
  level: 'info',
```

```
format: winston.format.json(),
transports: [
  new winston.transports.Console(),
  new winston.transports.File({ filename: 'logs/security.log' })
]
});

app.post('/login', (req, res) => {
  const { username } = req.body;

  logger.info(`Login attempt for user: ${username} at ${new
Date().toISOString()}`);

});
```

3. HTTPS & SECURITY CHECKLIST

To ensure data privacy in transit, I configured the local server to use HTTPS with SSL certificates.

HTTPS Configuration:

```
const https = require('https');
const fs = require('fs');

const options = {
  key: fs.readFileSync('certs/key.pem'),
```

```
cert: fs.readFileSync('certs/cert.pem')  
};  
  
https.createServer(options, app).listen(8443, () => {  
  console.log("Secure Server Listening on port 8443");  
});
```